

دليل تشغيل — تفعيل سقالات الأمان الخادمة

القسم operations-it-06 النوع runbook الحالة active المالك Founder آخر تحديث 21-06-2026

أنزل اختبار الفريق الأحمر في مايو 2026 ثلاثة إجراءات تحمين بوصفها سقالات خادمة، محكومة بالأعلام (PR #32). كلٌ منها معطل افتراضياً ولا يغيّر شيئاً في بيئة الإنتاج حتى تقوم (أ) بعمل العميل / الكونسول المطابق و(ب) تقلب علّمه. هذا الدليل هو إجراء التفعيل-عند-الاستعداد لكلٍ منها، بترتيب طرح آمن.

أما الإصلاحات التي هي فعّالة بالفعل (تخفيض حقن التاريخ المزور، وثبيت انتهاء صلاحية الاشتراك بـ 48 ساعة، والحصة المرتكزة على IP، وترويسات أمان captadel، وتحديد نطاق مفتاح CI) فلا تحتاج إلى شيء هنا — فقد سُحنت مُفعّلة افتراضياً.

كيف تُضبط هذه الأعلام. هي متغيرات بيئة عادية لدالة من الجيل الثاني، تُقرأ بالطريقة نفسها التي يُقرأ بها `ADEL_DAILY_FREE`. عيّنها في `functions/.env` (تحملها `firebase-functions` عند النشر) أو على بيئة خدمة `Cloud Run` في كونسول `Google Cloud`، ثم أعد نشر الدالة المتأثرة — إذ يُقرأ كل علّم عند تحميل الوحدة، لإعادة النشر (مراجعة جديدة) مطلوبة كي يسري المفعول. لا تودع أسراراً حقيقية في `functions/.env`؛ فهذه الثلاثة قيم منطقية غير سرّية.

التراجع للثلاثة جميعها واحد: ألغ تعيين العلّم (أو أعدّه إلى القيمة الافتراضية) وأعد النشر. ولا توجد هجرة بيانات مدقّرة — فإن `rcBindings` وحمولات `functions/protected/` إضافية.

1. App Check على `/api/chat` — `ADEL_APPCHECK_MODE`

يُغلق: نقطة نهاية LLM غير المصادق عليها (يستطيع أي أحد كتابة سكرت لـ `/api/chat` وإحراق ميزانية Gemini؛ CORSg ليس مصادقة). يؤثر في الدالة: `chat`. القيم: `off` (افتراضي) · `monitor` (تحقق وسجّل، دون حجب أبداً) · `enforce` (401 من دون رمز صالح).

ما تحتاجه أولاً

- سجّل App Check في كونسول App Check ← Firebase:
 - تطبيق Web ← موثّر reCAPTCHA Enterprise (أو reCAPTCHA v3).
 - تطبيق App Attest / DeviceCheck ← iOS (Capacitor).
- هَيّئ App Check في العميل كي تحمل الطلبات الرمز. للويب، في `assets/js/firebase-config.js` (أو مباشرة بعد `initializeApp`):

```
import { initializeAppCheck, ReCaptchaEnterpriseProvider }
  from 'https://www.gstatic.com/firebasejs/<ver>/firebase-app-check.js';
initializeAppCheck(app, {
  provider: new ReCaptchaEnterpriseProvider('<RECAPTCHA_SITE_KEY>'),
  isTokenAutoRefreshEnabled: true,
});
```

يستدعي `chat.js` بالفعل `/api/chat` عبر `fetch`؛ ومع تهيئة App Check، يرفق Firebase SDK ترويسة `X-Firebase-AppCheck` تلقائياً فقط عندما تستخدم نقل SDK callable. وبما أن `/api/chat` هو `fetch` عادي، اجلب الرمز صراحةً وأضف الترويسة:

```
import { getToken } from '.../firebase-app-check.js';
const { token } = await getToken(appCheck, /* forceRefresh */ false);
headers['X-Firebase-AppCheck'] = token;
```

افعل المكافئ في `js/chat.js` `captadel/public/assets/js/chat.js` إذا أردت أيضاً App Check على الخدمة المستقلة (ستحتاج إلى فحص خاص بها من جهة الخادم — وليس في هذا الـ PR).

الطرح (enforce ← monitor)

1. انشر تهيئة App Check للعمليات. اترك `ADEL_APPCHECK_MODE` غير معيّن.
2. عيّن `ADEL_APPCHECK_MODE=monitor` وأعد نشر `chat`. راقب السجلات: `appcheck monitor { result: 'valid' | 'absent' | 'invalid' }`
3. عندما تسجّل ~ كل حركة المرور الحقيقية `valid` (امنعها بضعة أيام + دورة إصدار تطبيق)، عيّن `ADEL_APPCHECK_MODE=enforce` وأعد النشر.

التحقق

```
# enforce mode: a request with no token is rejected
curl -s -o /dev/null -w '%{http_code}\n' -X POST https://flygaca.com/api/chat \
  -H 'Content-Type: application/json' -d '{"message":"test"}' # → 401
```

لا تقفز مباشرة إلى `enforce`. فمن دون تسجيل في الكونسول + عميل مشحون، يُصدر 401 enforce لكل مستخدم شرعي. راقب أولاً، دائماً.

2. ربط هوية RevenueCat — ADEL_RC_REQUIRE_BINDING

يُغلق: يمنح webhook المشتريات داخل التطبيق صفة Pro لأي `app_user_id` يختاره العميل، فيمكن لمشتري أن يلحق Pro بحساب اعتباطي. يؤثر في الدالة: `revenuecatWebhook` (+ `linkRevenueCatIdentity` القابلة للاستدعاء، المنشورة بالفعل). القيم: غير معيّن / `off` (افتراضي — يمنح على `app_user_id` كما اليوم) · صادق (1 / `true`) — يمنح فقط لـ `app_user_id` ذي ربط من جهة الخادم.

ما تحتاجه أولاً

1. اشحن استدعاء الربط في العميل. في مسار تسجيل الدخول على iOS (حيث يستدعي `assets/js/native-bridge.js` الأمر `Purchases.logIn(uid)`)، استدع أولاً القابلة للاستدعاء كي يوجد الربط قبل أي شراء:

```
import { getFunctions, httpsCallable } from '.../firebase-functions.js';
const fns = getFunctions(app, 'me-central1');
await httpsCallable(fns, 'linkRevenueCatIdentity')(); // writes rcBindings/{uid}
await Purchases.logIn({ appUserID: uid });
```

هذا غير قابل للتكرار التأثيري — آمن لاستدعائه في كل تسجيل دخول.

2. املأ المشتركين الحاليين بأثر رجعي كي لا تفقد اشتراكات Apple الحية الوصول عند قلب العلم. سكرت Admin SDK لمرة واحدة (يُشغّل محلياً مع حساب خدمة)، ينشئ ربطاً لكل uid يحمل حالياً استحقاق App-Store:

```
// backfill-rcbindings.js (node, firebase-admin)
const admin = require('firebase-admin'); admin.initializeApp();
const db = admin.firestore();
const snap = await db.collection('users')
    .where('entitlement.store', '=', 'APP_STORE').get(); // RC-sourced grants
const batch = db.batch();
snap.forEach((d) => batch.set(db.collection('rcBindings').doc(d.id),
    { uid: d.id, linkedAt: admin.firestore.FieldValue.serverTimestamp(), backfilled:
    true },
    { merge: true }));
await batch.commit();
console.log('backfilled', snap.size, 'bindings');
```

(إذا لم يكن `entitlement.store` مفهرساً/قابلاً للاستعلام، كرّر على كل المستخدمين وصف في الشيفرة).

الطرح

1. انشر استدعاء الربط في العميل (غير ضار ما دام العلم معطّلاً — فهو يكتب `rcBindings` فحسب).
2. شغل الملء بأثر رجعي مرة واحدة.
3. عيّن `ADEL_RC_REQUIRE_BINDING=1` وأعد نشر `revenuecatWebhook`.

التحقق

- شراء جديد من حساب مسجل الدخول يمنح Pro (الربط موجود).
- في السجلات، يُظهر حدثٌ لمعرّف غير مربوط `revenuecat grant skipped – no identity binding` ويعيد `200 skipped:unbound` (مُقرّب، لا مَمْنوح — لن يعيد RevenueCat المحاولة بكثافة).

`rcBindings` مجموعة خادمية فقط — يرفض `firestore.rules` كل وصول من العميل ويتجاوز Admin SDK القواعد، فلا يستطيع العميل قراءة ربط ولا تزويره. ولا حاجة إلى تغيير القواعد.

3. جدار دفع من جهة الخادم — ADEL_PROTECTED_CONTENT

يُغلق: كل حمولة "Pro" (بنك الأسئلة، المدرسة الأرضية، أجسام حزم التحضير) تُشخّن بوصفها ملفاً ثابتاً عاماً — اجلب عنوان الأصل بـ `curl` فيغدو جدار الدفع بلا معنى. لا يفعل `gate.js` سوى تمويه DOM بعد تحميل البيانات أصلاً. يؤثر في الدالة: `protectedContent (/api/content)`. القيم: غير معيّن / `off` (افتراضي — تعيد نقطة النهاية 501) · صادق — رمز + بوابة استحقاق حيّة.

قرار المنتج أولاً. شيفرتك حالياً فيها `WEB_GATING_LIVE=false` — المحتوى مفتوح عن قصد قبل الإطلاق. لا تفعل هذا حتى تريد فعلاً قفل جدار الدفع. فتفعله من دون تحويل العميل أدناه لن يترك سوى نقطة النهاية الجديدة تخدم 501 بينما تبقى الملفات الثابتة عامة — لا أسوأ، لكن لا أفضل. تأتي القيمة من إجراء كامل التحويل معاً.

التحويل (نقّذه كله، ثم اقلب العلم — راجع أيضاً `functions/protected/README.md`)

1. انقل الحمولات إلى جهة الخادم داخل `functions/protected/` وأضفها إلى قائمة السماح `CONTENT` في `functions/content.js`:

- `assets/data/quiz.json` ← `functions/protected/quiz.json` (المعرّف `quiz`)
- `assets/data/groundschool.json` ← `functions/protected/groundschool.json` (المعرّف `groundschool`)
- كل جسم حزمة تحضير ← `functions/protected/pack-<id>.json` (المعرّفات `pack-aip`, ...)

2. أوقف نشرها — أضف `assets/data/quiz.json` و `assets/data/groundschool.json`، وصفحات `packs/**` المحجوبة إلى `hosting.ignore` في `firebase.json`. (قائمة التجاهل مرشّح نشر، لا تحكم في الوصول — الحماية الحقيقية هي الخطوتان 1 + 4. حدّد شريحة المعاينة المجانية وأبقها عامة.)

3. حدّث العميل كي يجلب عبر البوابة مع رمز الهوية، ويعرض فقط على 200 (عالج 401 / 403 بمطالبة جدار الدفع). في `assets/js/study.js` و `assets/js/groundschool.js`، وصفحات الحزم:

```
import { getAuth } from '.../firebase-auth.js';
const idToken = await getAuth().currentUser?.getIdToken();
const res = await fetch('/api/content?id=quiz',
  { headers: idToken ? { Authorization: 'Bearer ' + idToken } : {} });
if (res.status === 401 || res.status === 403) { showPaywall(); return; }
const data = await res.json();
```

4. فَعِّل — عَيِّن `ADEL_PROTECTED_CONTENT=1`، وانشر الدوال و الاستضافة معاً (كي تختفي الملفات الثابتة وتغدو البوابة حيّة دفعة واحدة).

التحقق

```
# anonymous: no token → 401 (was: full JSON)
curl -s -o /dev/null -w '%{http_code}\n' https://flygaca.com/api/content?id=quiz # 401
# the old static URL is gone
curl -s -o /dev/null -w '%{http_code}\n' https://flygaca.com/assets/data/quiz.json # 404
# a signed-in Pro user (paste a fresh ID token) gets 200
curl -s -o /dev/null -w '%{http_code}\n' -H "Authorization: Bearer $ID_TOKEN" \
https://flygaca.com/api/content?id=quiz # 200
```

مراجع سريع

العلم	الافتراضي	الدالة	فعل بعد
ADEL_APPCHECK_MODE	off	chat	تسجيل App Check + تهيئة العميل؛ monitor ← enforce
ADEL_RC_REQUIRE_BINDING	off	revenuecatWebhook	شحن linkRevenueCatIdentity في العميل + تشغيل الملء بأثر رجعي
ADEL_PROTECTED_CONTENT	off	protectedContent	نقل الحمولات إلى جهة الخادم + إرسال العميل رمز الهوية + تحديث تجاهل firebase.json

تراجع الثلاثة جميعها بإلغاء تعيين العلم وإعادة النشر.